TECHNICAL REPORT

Third-Party Cybersecurity Risk Assessment Questionnaire

Project Objective

- Develop a structured questionnaire for initial cybersecurity review of software and service providers.
- Cover access management, incident response, data protection, backups, vulnerabilities, subcontractors, and assurance evidence.
- Use recognized cybersecurity frameworks and standards as reference points for question development.
- Define a transparent scoring method and consistent treatment of unanswered or not-applicable questions.
- Provide a repeatable process for recording evidence, identifying gaps, and recommending follow-up actions.

Background Research

1 NIST Cybersecurity Framework (CSF) 2.0

NIST CSF 2.0 provides high-level cybersecurity outcomes to help organizations understand, assess, prioritize, and communicate cybersecurity risk. Its six functions are Govern, Identify, Protect, Detect, Respond, and Recover. It is outcome-oriented rather than a ready-made vendor questionnaire. In this project, its outcomes inform questions about governance, dependencies, access control, data security, incident handling, and recovery.2 NIST Supply-Chain Risk Management Guidance

NIST SP 800-161 Rev. 1 addresses cybersecurity supply-chain risk management for systems and organizations. It discusses identifying, assessing, and mitigating risks associated with products and services obtained from external parties. It is relevant to supplier risk, subcontractors, security requirements, and ongoing oversight. The official publication page should be checked for current status and updates before citing a particular revision in future work.

2.3 CIS Critical Security Controls

The CIS Critical Security Controls provide prioritized safeguards to help organizations improve cybersecurity. Relevant themes include account management, access control, vulnerability management, and data recovery. These themes informed the practical wording of several questions. This questionnaire does not claim to implement or assess all CIS safeguards.

2.4 ISO/IEC 27001:2022

ISO/IEC 27001 specifies requirements for establishing, implementing, maintaining, and continually improving an information security management system. Its risk-based management approach and control themes provide context for questions about policies, responsibilities, supplier relationships, incident management, and information protection. The standard is copyrighted and may require purchase; this report does not reproduce its full text or claim formal conformity.

2.5 AICPA SOC Resources

AICPA resources describe SOC engagements and reports for service organizations. A SOC report may provide independent assurance about controls within a defined scope and period. Its existence alone does not prove every questionnaire control is satisfied. Reviewers should examine report type, scope, period, exceptions, and relevance to the service being assessed.

Methodology

This project uses a desk-based design methodology. Public framework and standards resources were selected for relevance to third-party cybersecurity risk. Their high-level topics were mapped to practical questions written in plain language and grouped into control domains.

1. Define the purpose: initial screening before onboarding, renewal, or access to sensitive information.
2. Identify control domains using NIST CSF 2.0, NIST supply-chain guidance, CIS Controls, ISO/IEC 27001, and AICPA SOC resources.
3. Write questions that can be answered by an authorized provider security, IT, compliance, or service owner contact.
4. Define responses: Yes, Partially, No, Unknown, and Not applicable with justification.
5. Create a scoring model and specify how evidence gaps and critical weaknesses are handled.
6. Document the limits of self-reported answers and request evidence proportionate to risk.
7.



Questionnaire Design and Scope

The deliverable contains 30 adapted assessment questions in seven domains. They are informed by source topics and are not represented as verbatim quotations from NIST, CIS, ISO/IEC, or AICPA publications.

Domain	Question numbers	Purpose
Governance and risk management	1–4	Review policy ownership, risk review, and business dependencies.
Access controls	5–8	Review unique accounts, MFA, least privilege, and access reviews.
Data handling and privacy	9–12	Review encryption, authorized data access, retention, and privacy obligations.
Incident response	13–16	Review planning, notification, investigation, and exercises.
Backups and continuity	17–20	Review backup protection, restoration tests, and recovery objectives.
Vulnerability management	21–24	Review scanning, remediation, security testing, and patching.
Subcontractors and assurance evidence	25–30	Review supplier oversight, contractual safeguards, assurance evidence, and remediation tracking.

Scoring and Evaluation Approach

The proposed scoring model provides a simple initial comparison. It is a project-defined method, not a scoring rule mandated by the referenced frameworks.

Response	Points	Treatment
Yes	2	Reported as implemented; verify important answers with evidence.
Partially	1	A gap, limited coverage, or incomplete implementation exists.
No	0	Reported as not implemented.
Unknown	0	Unresolved information gap pending follow-up.
Not applicable	Exclude	Exclude only with a reasonable explanation consistent with service scope.

Formula: Score (%) = (points earned ÷ maximum points for applicable questions) × 100.

If all 30 questions apply, the maximum score is 60. A justified Not applicable answer is removed from the denominator, not awarded points.

Score band	Suggested interpretation	Suggested action
85–100%	Lower apparent risk	Review key evidence and record the approval rationale.
65–84%	Moderate apparent risk	Request evidence and agree remediation owners and deadlines.
Below 65%	Higher apparent risk	Escalate for deeper review; consider deferring approval until material gaps are addressed.

These bands are illustrative project criteria and have not been empirically validated. The score is not certification or a guarantee of security. A critical weakness—such as inadequate privileged-access protection or no viable recovery capability for a critical service—may require escalation even if the total score is high.

Handling Unanswered Questions and Evidence

- Do not treat a blank response as Yes; record it as Unknown until clarified.
- Request a response and proportionate evidence with a clear deadline.
- Score Unknown as zero for initial screening and flag it separately as an information gap. Recalculate if adequate information is later supplied.
- Accept Not applicable only when the provider gives a rationale consistent with the service scope.
- Escalate unresolved answers to critical questions before approving access to sensitive data or production systems.
- Record the evidence reviewed, date, scope, relevance, and limitations. Do not request passwords, API keys, or unnecessary sensitive data.
- For each gap, document impact, compensating controls, action owner, target date, and the decision to accept, mitigate, defer, or reject residual risk.

Tools and Technologies

The questionnaire and report can be prepared in Microsoft Word or an equivalent word processor. Microsoft Excel or Google Sheets can record responses, calculate scores, and track remediation. Official NIST and other framework websites serve as desk-research sources. GitHub can store versioned documentation and the README. Google Forms is optional for electronic response collection and is not required by the provided task instructions unless a supervisor specifically asks for it.

This report does not claim that a provider was contacted, that a form was deployed, that responses were collected, or that a spreadsheet calculation was tested. Add those activities only after they have actually been completed.

Work Performed and Current Results

The work documented consists of defining the questionnaire purpose and scope; reviewing public framework and assurance resources at a high level organizing 30 draft questions into seven domains; proposing response options and a scoring rubric and defining the handling of Unknown, Not applicable, evidence gaps, and critical findings.

The current result is a structured questionnaire design and evaluation method. No empirical findings about an actual vendor are reported because no verified provider responses or supporting evidence have been supplied. The score bands are proposed criteria, not results from a completed assessment.

Testing or Evaluation Plan

No live assessment or technical control test is claimed as completed. After a provider participates, the following checks are recommended:

- Check that every question has a response or an explicit Unknown / Not applicable status.
- Check that Not applicable answers include a rationale.
- Recalculate a sample of scores manually to verify spreadsheet formulas.
- Review a sample of evidence for date, scope, relevance, and consistency with the provider's answers.
- Escalate critical weaknesses and unresolved high-impact Unknown responses separately from the score.
- Record clarifications and preserve an assessment trail.

Limitations

- The questionnaire depends on the accuracy and completeness of provider self-reporting.
- Equal weighting may not reflect the different business impact of individual controls.
- The score bands are illustrative and have not been empirically validated.
- The questionnaire is an initial screening tool, not a full audit, penetration test, legal assessment, certification, or guarantee of security.
- Framework mapping here is at topic level; exact control identifiers should be verified against current official sources before formal submission.
- No actual provider assessment, independent evidence verification, or operational control testing is claimed as completed in this version.

Recommendations

- Tailor questions to the service, data sensitivity, system access, and business criticality.
- Verify the current status and version of each cited publication before final submission.
- Map each question to an exact NIST CSF subcategory or relevant control reference if formal traceability is required.
- Prioritize privileged access, incident notification, data protection, recovery, and critical vulnerability remediation.
- Document exceptions, owners, and due dates for material gaps.
- Reassess after material changes to service, hosting, data processing, or subcontractors.
- Include the report, questionnaire, README, and video link in the repository; do not publish confidential information or secrets.

Conclusion

This project establishes a practical starting point for third-party cybersecurity risk assessment by translating recognized framework themes into 30 plain-language questions, response options, and a transparent initial scoring approach. The questionnaire is most useful as a structured, evidence-supported review—not as a standalone numerical verdict. A final assessment requires actual provider responses, appropriate evidence review, consideration of critical weaknesses, and documented decisions. The questionnaire and methodology can be refined through assessment experience and supervisor feedback.

References

- National Institute of Standards and Technology (NIST). (2024). Cybersecurity Framework (CSF) 2.0. Official resource. https://www.nist.gov/cyberframework
- NIST. Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations, SP 800-161 Rev. 1. Consult the official page for current status and updates. https://csrc.nist.gov/pubs/sp/800/161/r1/final
- Center for Internet Security (CIS). CIS Critical Security Controls. https://www.cisecurity.org/controls
- International Organization for Standardization (ISO). ISO/IEC 27001:2022 — Information security management systems — Requirements. https://www.iso.org/standard/27001
- AICPA. System and Organization Controls (SOC) resources for service organizations. https://www.aicpa-cima.com/resources/landing/system-and-organization-controls-soc-suite-of-services